GERMAN-MALAYSIAN INSTITUTE

Training for Advanced Technology

CBS 2332
QUESTION 2: The Shadow IT Audit

Date: 4 March 2026

TTO Name:
Ms. Farazilawati Baizura Binti Mohd Pooad

NO.	STUDENT NAME	STUDENT ID
1.	Abdul Hariz Mohd bin Sarnudin	CBS24070208
2.	Muhammad Hazeeq bin Nurazlan	CBS24070509
3.	Muhammad Danial bin Norhisam	CBS24070222
4.	Putri Nabila binti Zainol Abiddin	CBS24070214

Since you are teaching IT Management, a core skill students often struggle with is **Shadow IT**—when employees use unauthorized software or hardware without the IT department's knowledge. Here is a simple, highly interactive group task focused on **IT Governance and Security.**

Scenario

A marketing firm recently moved to a "Work From Home" model. The IT department has discovered that the Marketing Team is using **Trello** for project management and **personal Dropbox accounts** to share client files, rather than the company's official (but slower) internal SharePoint site.

The Marketing Director argues that the official tools "slow them down" and they need these apps to meet deadlines.

The Task

Divide the students into groups (4 Members) and develop a **Shadow IT Resolution Plan**. They must address the following four points:

🎬 **The Analysis:** List two specific security or compliance risks created by the team using personal Dropbox accounts for client data. (What security risk the company will face)

🎬 **The Compromise:** Will you **Block** the apps (Strict Governance) or **Bless** them (Incorporate them into the official IT stack)? Explain why. (Block, give rational)

🎬 **The Cost of Governance:** If you decide to "Bless" (officially support) Trello and Dropbox, what are two new responsibilities the IT department now has? (e.g., license costs, SSO integration, backups). (Cost needed to enhance the company dropbox)

🎬 **The Policy:** Write a two-sentence "Acceptable Use" rule that allows for innovation but prevents employees from installing software secretly in the future. (update company policies)

Why this works:

- **Real-world Tension:** It simulates the classic conflict between "IT Control" and "User Productivity."
- **Governance:** It introduces students to the concept of **IT Policies** without being boring.
- **Security awareness:** It helps them see how a "useful" app can be a "dangerous" security hole.

The risk to the company

The specific security and compliance risks created by the team using personal Dropbox accounts for client data includes :

1. **Risk Legal E-Discovery and Spoliation of Evidence**

   In the event of litigation or a formal audit, the company is legally obligated to produce all relevant documents including project management notes and file versions. Because these documents reside in personal accounts, IT cannot perform a “Legal Hold”.

   The impact :

   If the employee deletes a folder during a lawsuit, even by accident, the company can be accused of spoliation of evidence. This can lead to “adverse inference” rulings where the judge assumes the deleted evidence was guilty and potentially costing the firm millions in legal settlements.

2. **Data Orphanage and Offboarding Gaps**

   In the event of an employee resignation, termination and even internal department transfer, the company lacks the administrative authority to revoke access to personal accounts. Since these files are stored in a private environment, the IT department cannot perform a “Remote Wipe” or transfer ownership of the data to a successor.

   The impact :

   If the employee leaves the firm to work for a competitor, they retain full access to sensitive client files and intellectual property on their personal devices, Furthermore, if an account is closed by the individual, the company suffers a permanent loss of “Corporate Memory”, leading to project delays and a total inability to recover critical business assets.

Action taken for company security

We will block the use of Trello and personal Dropbox and require the marketing team to use the company's official share system. Here's why:

1. **Company Loses Control of Its Own Files**

   When employees use personal accounts, they own the account, not the company. This is a huge problem:

   What happened when an employees quit or get fired:

   i) All client files stored in their personal Dropbox leave with them

   ii) Company has no legal right to access their personal account

   ii) They could give the files to company's competitor

2. **Causes Loss of Centralized IT Control**

   If we allow marketing to use their own apps, every department will demand the same treatment:

   The domino effect:

   i) Marketing gets approval to use Dropbox and Trello today

   ii) Sales team demands Slack because marketing received their preferred apps

   iii) Design team wants Adobe Creative Cloud personal accounts since everyone else got their tools

   Result after 6 months:

   i) Company now has 15-20 different apps scattered across departments

   ii) Client files are stored in 5 different cloud systems and nobody knows where anything is

   iii) IT department cannot support any of them properly because systems are too fragmented

3. **Wasteful Spending instead of Fixing the Real Problem**

The company already owns SharePoint, so paying for new tools wastes money instead of solving the actual issue:

We already paid for the solution:

i) Microsoft 365 with SharePoint is already purchased and fully paid for by the company

ii) SharePoint has all the features marketing needs including file storage and collaboration tools

iii) Buying Dropbox and Trello means paying twice for the same functionality we already own

The real problem is fixable:

i) Marketing complains SharePoint is slow, but this is a technical problem that can be fixed

ii) Upgrading and optimizing SharePoint is a one-time investment versus paying subscription fees forever

iii) Proper training and system optimization will make SharePoint faster than the unauthorized tools

The costs of actions taken

Technical Enforcement Costs (Firewall/Blocking) :

Purchase and configure “Cloud Access Security Broker” (CASB) tools or firewall rules to actively block traffic to personal cloud storage sites (Dropbox) on all company devices to enforce the ban of use.

IT is now responsible for deploying and managing Cloud Access Security Broker (CASB) software or updating firewall rules. They must actively monitor network traffic to detect and block connections to unauthorized domains (like dropbox.com or trello.com) on all company devices to ensure the policy is actually enforced, not just ignored.

Infrastructure Optimization (OneDrive Sync) :

To mitigate the "slowness," IT must invest labor hours in deploying and maintaining the "OneDrive for Business" sync client, allowing Marketing to work on files locally (eliminating VPN lag) while syncing to the official SharePoint backend.

IT is now responsible for configuring and deploying OneDrive for Business Sync Clients to all marketing workstations. This allows employees to edit files locally on their desktops (at high speed) while syncing to the server in the background, replicating the "Dropbox experience" within the official IT stack.

Future proofing guidelines

“ Employees are encouraged to propose innovative tools or applications that could improve productivity. However, all and any software, cloud services, and file-sharing platforms must receive prior written approval from the IT department before any use for company-related work. Furthermore, unauthorized installation, download, or use of non-approved tools including personal accounts on services is strictly prohibited to protect data security and compliance of the company.”

-Hazeeq © 2026

This rule stands out as a best practice for managing shadow IT because it effectively balances encouraging innovation with maintaining strict security controls. By proactively inviting employees to propose new productivity tools, it channels creativity into official paths rather than driving unapproved usage underground. This positive tone reduces frustration and the temptation to bypass policies, ensuring that employee ideas are valued rather than punished.

Simultaneously, the policy maintains firm oversight by requiring written IT approval for any software or cloud service, allowing for thorough risk and compliance checks before company data is exposed. This mandatory checkpoint ensures that security remains a priority while positioning IT as a supportive partner rather than just a roadblock. Ultimately, this collaborative approach fosters a secure workplace where high compliance is achieved through cooperation rather than fear.

Reference

- **BetterCloud. (n.d.). The IT leader's guide to managing shadow IT.** https://www.bettercloud.com/monitor/managing-shadow-it

- **vBoxx Team. (n.d.). *Eight security risks of Dropbox, OneDrive and Google Drive*. vBoxxCloud.** https://vboxxcloud.com/blog/security-risks-dropbox-onedrive-google/

- **CyCognito. (n.d.). *Shadow IT: Top 5 risks & 5 ways to mitigate them*.** https://www.cycognito.com/learn/cloud-security/shadow-it/